TP2 — Gestion avancée des utilisateurs et des groupes

Andrea Garcia Magnanon · BTC2 · 3 novembre 2026

1. Environnement et organisation des comptes

Dans ce TP, j'ai repris le serveur Hélios du TP1 pour donner des droits différents aux membres de l'équipe transport, à l'analyste télémétrie et à un auditeur externe. L'objectif était de vérifier les droits avec les comptes concernés, en conservant les refus aussi bien que les réussites.

J'ai travaillé sur **srv-core**, sous Rocky Linux 9.8, dans VirtualBox. Le collecteur `helios-collect.service` était actif avant les modifications. Le snapshot **01-fin-TP1** a été créé avant de commencer. L'administration s'est faite par SSH sur le port local 2221. Le compte de service `helios`, déjà présent au TP1, a été conservé.

La racine de cette VM est en **ext4**, contrairement au XFS annoncé dans l'énoncé. La sortie de `mount` le confirme. Les tests montrent que les ACL POSIX fonctionnent sur cette installation ; aucun reformatage n'était nécessaire.

Compte	UID	Groupe principal	Groupe supplémentaire	Rôle
julien	5100	transport (5000)	helios-ops (5002)	Chef d'équipe, délégation sudo
nadia	5101	transport (5000)	transport, ajouté par gpasswd	Exploitation transport
tarek	5102	telemetry (5001)	transport	Analyse télémétrie
audit-ext	5103	telemetry (5001)	—	Lecture seule, mandat de 21 jours

J'ai réglé `login.defs` **avant** la création des comptes : validité de 90 jours, minimum de 1 jour entre deux changements, avertissement de 14 jours et umask 027. Le squelette ajoute `EDITOR=vim`, un historique de 5 000 commandes et leur date, sans imposer un deuxième umask dans `.bashrc`.

Julien est administrateur du groupe `transport` avec `gpasswd -A julien transport`. Son ajout de Nadia a réussi sans droits root. `getent group` n'affiche pas automatiquement les membres dont `transport` est déjà le groupe principal ; c'est pourquoi j'ai contrôlé aussi `id` et `/etc/gshadow`.



Figure 1 — Comptes et politique appliquée.

Les images du rapport sont des captures réelles de la console VirtualBox **affichant des extraits de résultats SSH enregistrés**, identifiés comme tels. Les transcriptions complètes sont dans `captures/`. Elles ne représentent pas une nouvelle exécution des commandes au moment de la capture.

2. Politique de mot de passe et verrouillage

Le fichier `50-helios.conf` exige au moins **12 caractères**, **3 classes de caractères** et au maximum **3 caractères identiques consécutifs**. `dictcheck` active le contrôle du dictionnaire et `usercheck` vérifie la présence du nom d'utilisateur. `enforce_for_root` applique également ces contraintes lorsque root change un mot de passe.

L'installation issue du TP1 n'avait pas de profil authselect enregistré. Après sauvegarde des fichiers PAM, j'ai sélectionné le profil `sssd` avec `with-faillock`. Les comptes de ce TP restent locaux ; la sélection du profil ne signifie pas qu'un annuaire distant a été configuré. `authselect check` confirme la cohérence de la configuration.

J'ai fixé le seuil à **5 échecs**, une fenêtre de **900 secondes** et un déverrouillage après **600 secondes**. L'option `audit` complète les informations de journalisation. Six mauvaises authentifications de Nadia ont été tentées depuis Tarek : cinq échecs figurent dans `faillock`, puis le compte est bloqué. Le reset vide bien le compteur.

Pour tester la qualité du mot de passe, j'ai antidaté d'un jour le dernier changement de Julien. Cela évite que le minimum de 1 jour bloque le test avant même le contrôle de qualité. Dans un terminal SSH avec pseudo-terminal, `passwd` refuse **helios**, qui compte six caractères : `BAD PASSWORD: The password is shorter than 12 characters`. J'ai ensuite interrompu la saisie ; son mot de passe n'a pas été remplacé.

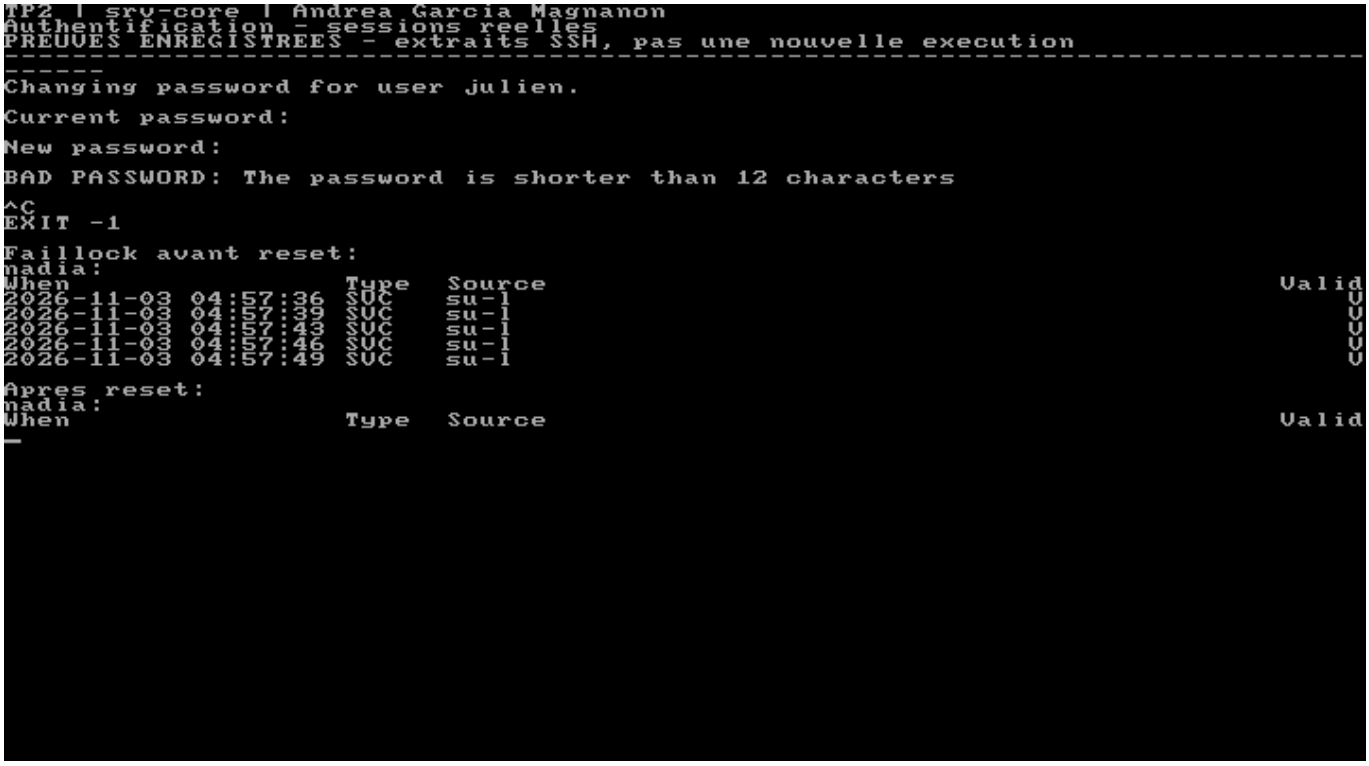


Figure 2 — Refus du mot de passe faible et compteur avant/après reset.

Le contrôle final de Julien donne un maximum de **90 jours**, un avertissement de **14 jours** et une inactivité de **7 jours** après expiration du mot de passe. L'échéance du mot de passe est le **31 janvier 2027**, compte tenu de l'antidatage du 2 novembre. Le compte `audit-ext` expire le **24 novembre 2026**, soit 21 jours après sa création. L'expiration du compte et celle du mot de passe sont deux mécanismes distincts.

Preuves : `comptes.txt`, `mot-de-passe-faible.txt`, `faillock-avant-reset.txt` et `faillock-apres-reset.txt`.

3. Héritage setgid et protection sticky

J'ai créé le répertoire de travail `/srv/helios/projets/transport` avec Julien comme propriétaire, `transport` comme groupe et le mode **2770**. Le bit setgid impose le groupe du répertoire aux nouveaux fichiers. Le répertoire `temoin`, en **0770**, permet la comparaison.

Nadia a pour groupe principal `transport` : ses fichiers ont ce groupe dans les deux répertoires. Son test seul ne démontre donc pas l'effet du setgid. Le résultat de Tarek est plus parlant :

Fichier créé par Tarek	Groupe observé	Explication
`transport/tournee-tarek.csv`	transport	Groupe hérité du répertoire setgid
`temoin/y`	telemetry	Groupe principal du créateur

Le dépôt commun `/srv/helios/depot` est en **1777**. Tout le monde peut y déposer un fichier, mais le sticky bit limite la suppression et le renommage à son propriétaire, au propriétaire du répertoire et à root.

J'ai créé `fichier-nadia` avec Nadia, puis essayé de le supprimer avec Tarek. En mode 1777, `rm` échoue avec **rc=1** et « Opération non permise ». Après passage temporaire en 0777, la suppression réussit avec **rc=0**. J'ai immédiatement rétabli le mode 1777.

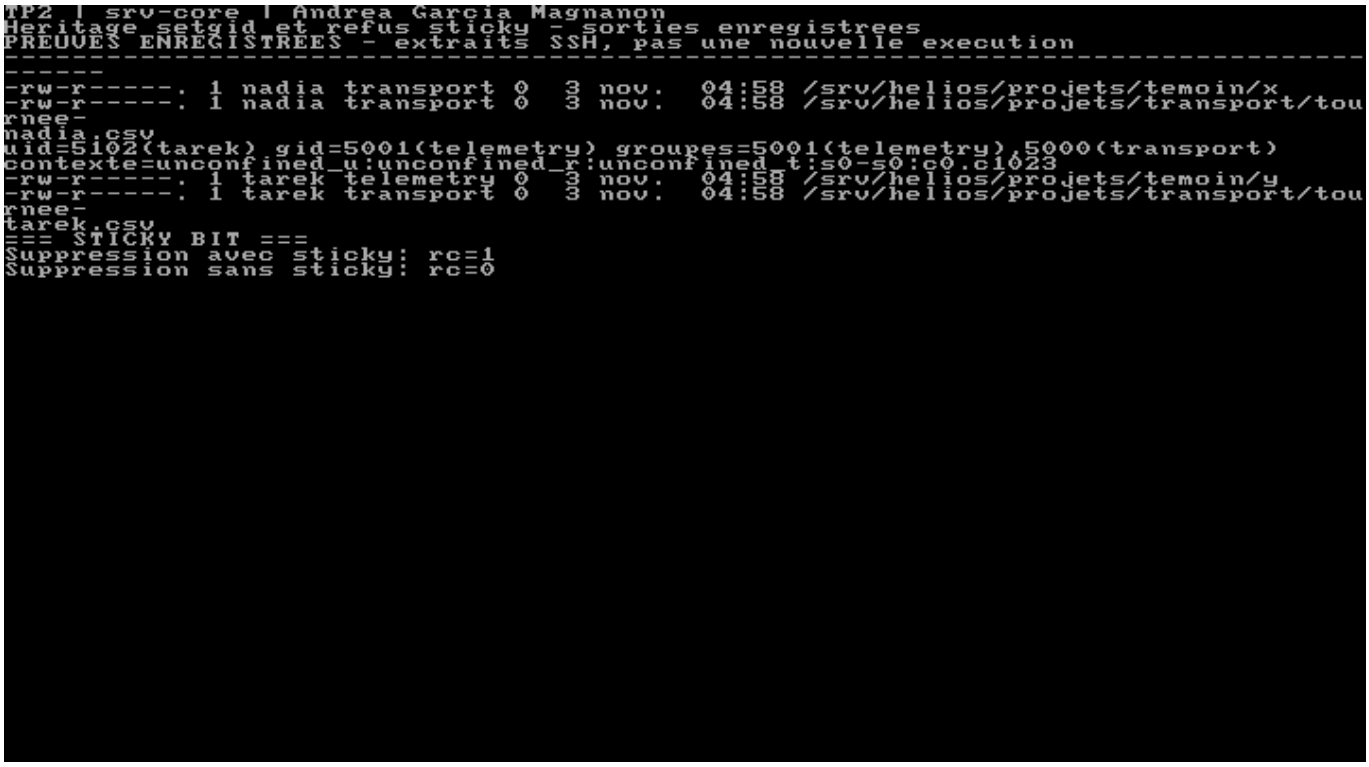


Figure 3 — Groupes des fichiers et comparaison avec/sans sticky bit.

Au contrôle final, les modes sont `drwxrws---+` pour le projet transport, `drwxrwx---` pour le témoin et `drwxrwxrwt` pour le dépôt. Le + du projet indique la présence d'ACL ; il ne remplace pas le bit setgid.

Le sticky bit ne garantit pas la confidentialité du contenu. Il contrôle les opérations sur les noms dans le répertoire ; les droits du fichier continuent de régler sa lecture et sa modification.

Preuves : `permissions.txt` et `controle-final.txt`.

4. Umask, inventaire et binaire privilégié

J'ai noté les modes attendus avant les mesures. Sans ACL par défaut, un fichier ordinaire part de **0666** et un répertoire de **0777**. Le mode est obtenu par `mode demandé & ~umask` ; il ne s'agit pas d'une soustraction générale.

Cas	Umask	Fichier prédit	Fichier observé	Dossier prédit / observé
Session initiale Nadia	027	640	640	750 / 750
Masque collaboratif explicite	002	664	664	775 / 775
Masque privé explicite	077	600	600	Non demandé

Le script `helios-umask.sh` teste l'appartenance au groupe `transport` : ces membres reçoivent **002**, les autres **027**. Après son installation, Nadia affiche 0002 et l'auditeur 0027. Une ACL par défaut peut ensuite prendre le relais pour déterminer les droits hérités du projet.

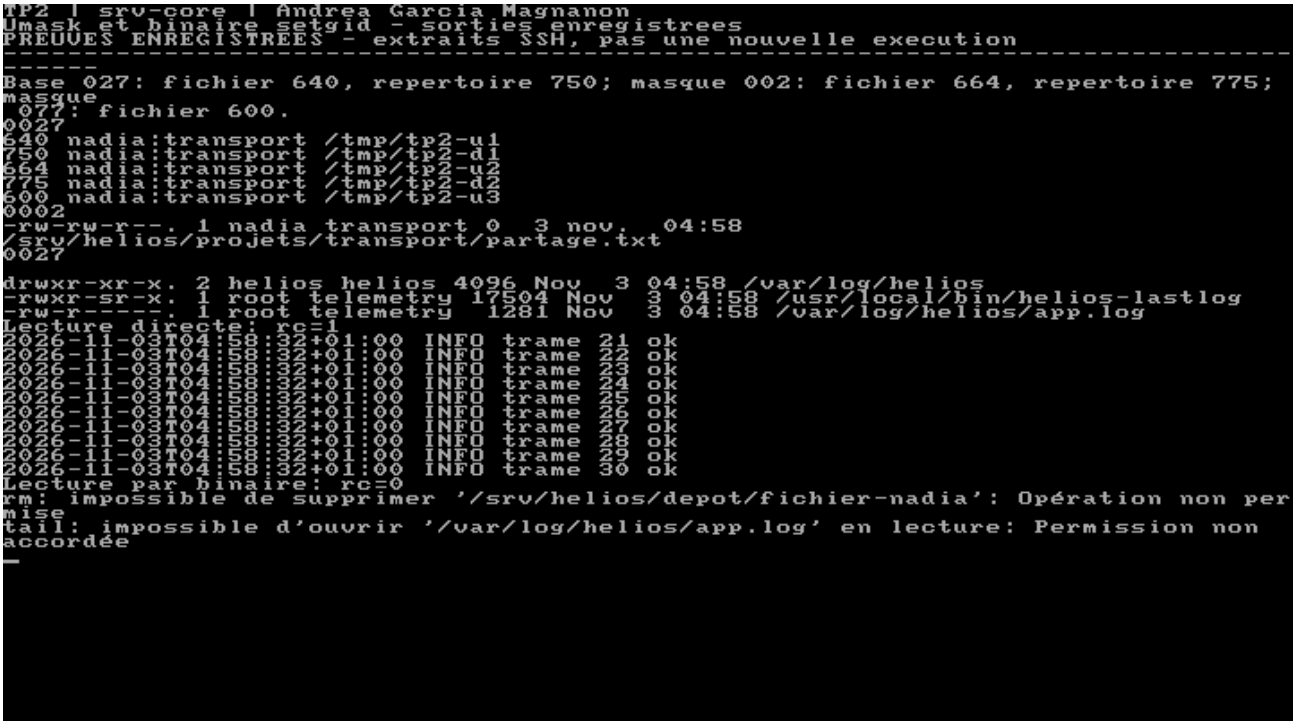


Figure 4 — Mesures des umask et lecture par le binaire setgid.

L'inventaire complet des binaires setuid/setgid est conservé dans `inventaire-bits-speciaux.txt`. Trois exemples observés : **passwd**, setuid root, peut modifier les données d'authentification après vérification de l'utilisateur ; **su**, setuid root, change d'identité selon les contrôles PAM ; **gpasswd**, setuid root, met à jour les groupes et leur fichier protégé en contrôlant les droits de l'appelant. Leur présence se justifie par ces opérations ; elle ne dispense pas de maintenir les paquets à jour.

Un script appartenant à root avec le mode 4755 affiche toujours **uid=5101(nadia)** lorsqu'elle l'exécute : Linux ignore le setuid sur ce script interprété. Le script de démonstration a été supprimé.

J'ai compilé `helios-lastlog.c`, puis installé le binaire **root:telemetry en 2755**. Le fichier `app.log` est en **0640 root:telemetry**. Julien échoue en lecture directe avec `tail` (**rc=1**), mais le binaire affiche les dix dernières lignes (**rc=0**). Le groupe effectif apporte le droit de lecture ; le programme n'a pas besoin d'être setuid root. `execle` lance un chemin fixe, sur un journal fixe, avec un environnement fixé par le code ; aucun chemin fourni par l'appelant n'est accepté.

5. ACL nominatives et héritage durable

L'auditeur n'appartient pas à `transport`. J'ai ajouté une entrée nominative `u:audit-ext:rX` aux éléments existants. Le `X` donne la traversée aux répertoires et l'exécution aux fichiers déjà exécutables. Les fichiers ordinaires de ce test restent en lecture seule pour l'auditeur. La lecture réussit et la création d'un fichier est refusée.

Le test d'un nouveau fichier avant les ACL par défaut a révélé un piège : avec l'umask **002**, il est créé en **0664**. L'auditeur peut donc le lire grâce à `other::r--`, même sans ACL nominative. Après retrait de ce droit et vérification de l'absence d'ACL sur le fichier témoin, sa lecture échoue bien (**rc=1**). Une simple lecture réussie ne suffisait donc pas à démontrer l'héritage.

J'ai ensuite posé les ACL par défaut du sujet. Le nouveau fichier `tournee-j2.csv` devient lisible automatiquement. En revanche, l'entrée par défaut `audit-ext:r--` ne permet pas d'entrer dans le nouveau sous-répertoire `semaine-41` : le test de `cd` échoue.

J'ai corrigé l'entrée par défaut en **audit-ext:r-x**. Les fichiers ordinaires créés avec le mode demandé 0666 n'obtiennent pas pour autant un droit d'exécution effectif : leur masque hérité est `rw-`. L'auditeur peut désormais traverser les sous-dossiers et lire leurs fichiers, sans pouvoir créer ni modifier un document.

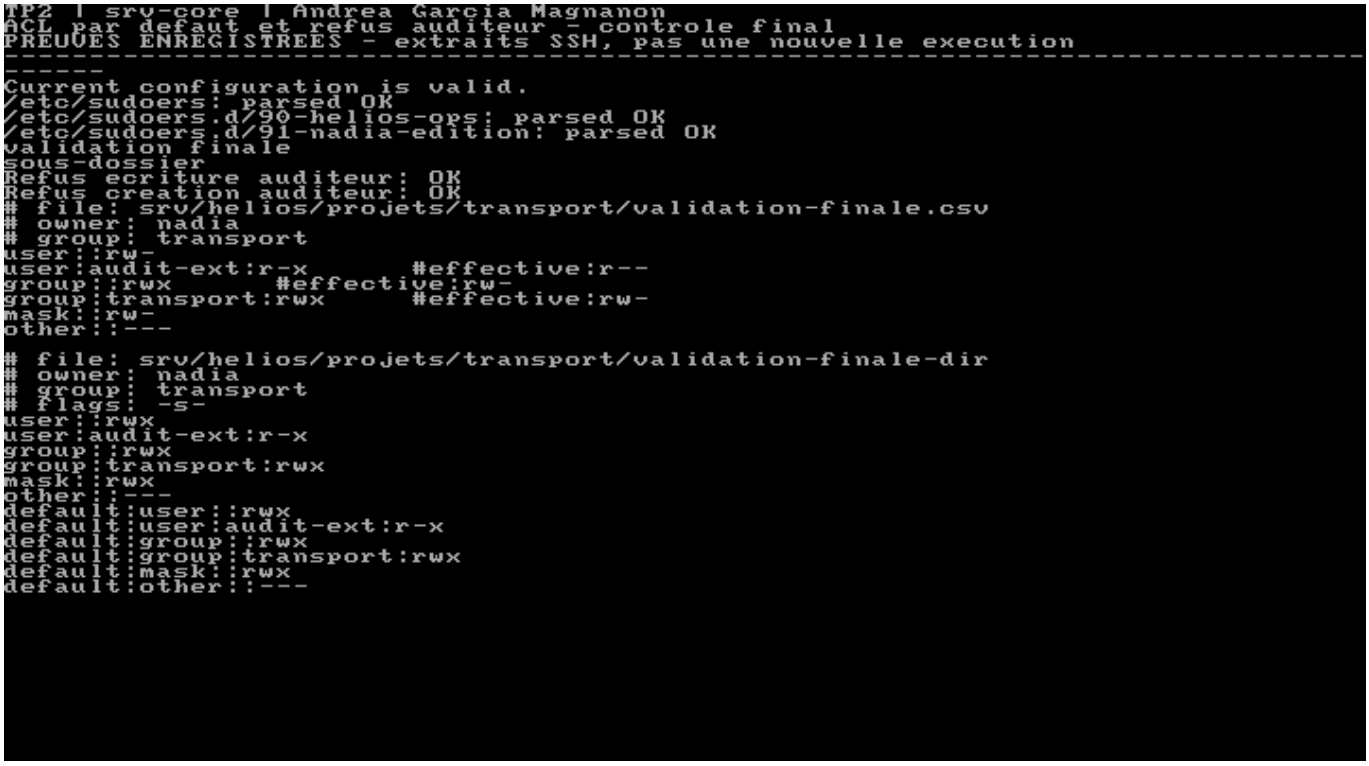


Figure 5 — ACL héritées et refus d'écriture au contrôle final.

La configuration finale du projet comporte `default:user:audit-ext:r-x`, `default:group:transport:rwx` et `default:other::---`. J'ai également retiré les droits `other` des fichiers créés avant ces ACL. Les fichiers ordinaires ont un masque `rw-`, pour éviter qu'un recalcul du masque ne réactive des droits d'exécution présents dans certaines entrées héritées.

Le contrôle final crée un nouveau fichier et un nouveau sous-dossier depuis Nadia. L'auditeur lit le fichier et celui du sous-dossier ; son ajout de texte et sa création d'un fichier sont tous deux refusés. Preuves : `acl.txt`, `controle-final.txt` et sauvegarde d'ACL dans `configs/`.

6. Effet du masque ACL et sauvegardes

Sur `tournee-j2.csv`, j'ai accordé `u:tarek:rwx`. Avant modification, le masque vaut `rwx` et cette entrée est pleinement effective. Après `chmod g-w`, l'entrée de Tarek contient toujours `rwx`, mais `getfacl` affiche **#effective:r-x** : le masque est devenu `r-x`. Son ajout de texte échoue avec **rc=1**. Après `setfacl -m m::rwx`, la même écriture réussit avec **rc=0**.

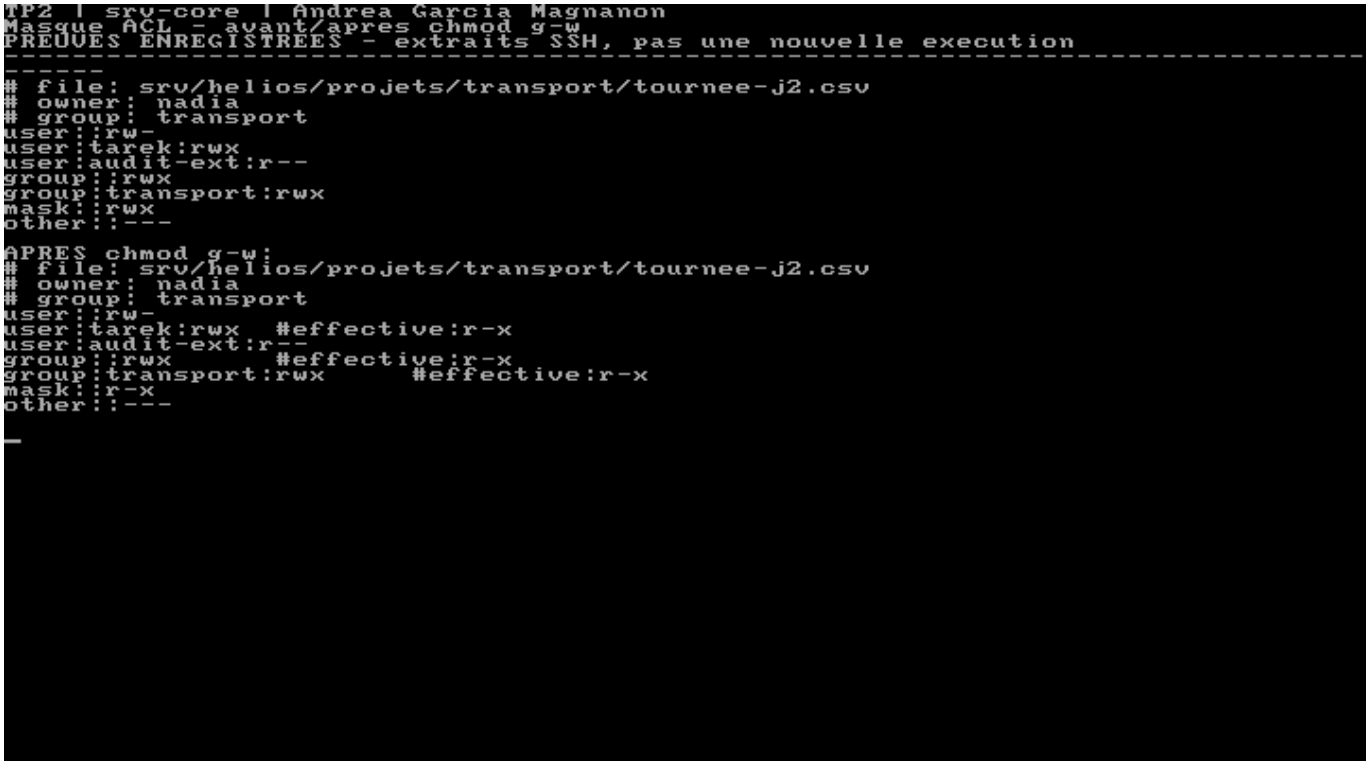


Figure 6 — Entrées ACL inchangées, masque et droits effectifs modifiés.

Sur un fichier avec ACL étendue, les bits de groupe affichés par `ls -l` correspondent au **masque ACL**. `chmod g-w` retire donc l'écriture au masque, ce qui limite le groupe propriétaire, les utilisateurs nommés et les groupes nommés. Il ne supprime pas les permissions inscrites dans leurs entrées. Le propriétaire du fichier et `other` ne sont pas limités par ce masque. Les droits effectifs de Tarek sont l'intersection entre son entrée nominative et le masque.

Pour sauvegarder les ACL, j'ai exécuté `getfacl -R transport`, retiré les ACL étendues avec `setfacl -R -b`, puis restauré la sauvegarde avec `setfacl --restore`. Une comparaison avant/après ne montre aucune différence. Les droits, propriétaires, groupes et indicateurs sont présents dans la sauvegarde.

La copie avec **cp -a** conserve les ACL dans le test ; la copie avec **cp -r** n'affiche plus les entrées nominatives et par défaut. J'ai également créé `transport.tgz` avec **tar --acls --xattrs**. Les deux copies témoins ont ensuite été supprimées.

La sauvegarde définitive `acl-transport-2026-11-03.txt` et l'archive ont été refaites après les derniers contrôles, pour correspondre à l'état final. Pour une restauration, il faut se placer dans `/srv/helios/projets` car les noms de la sauvegarde sont relatifs. Le test du masque reste documenté dans les deux captures avant/après ; le masque final des fichiers ordinaires est ramené à `rw-`.

7. Délégation sudo et traçabilité

Julien appartient à `helios-ops`. Le fichier `90-helios-ops` autorise les actions prévues sur le collecteur et la cible Hélios, la lecture limitée des journaux et deux lectures sous l'identité de service `helios`. Il n'accorde pas un accès général à root.

Les paramètres imposent un cache d'authentification de **5 minutes**, **2 essais** de mot de passe et l'affichage de la notice. `log_output` enregistre les sorties ; `iolog_dir` les place dans `/var/log/sudo-io` ; `logfile` écrit les événements dans `/var/log/sudo-helios.log`. `visudo -c` valide les deux fichiers de règles finaux.

Test final	Résultat
Julien : redémarrer helios-collect.service	Autorisé, rc=0
Julien : redémarrer sshd	Refusé, rc=1
Julien : journal Hélios, 5 lignes, sans pager	Autorisé, rc=0
Julien : ajouter `-u sshd` à cette commande	Refusé, rc=1
Tarek ou audit-ext : redémarrer le collecteur	Refusé, rc=1

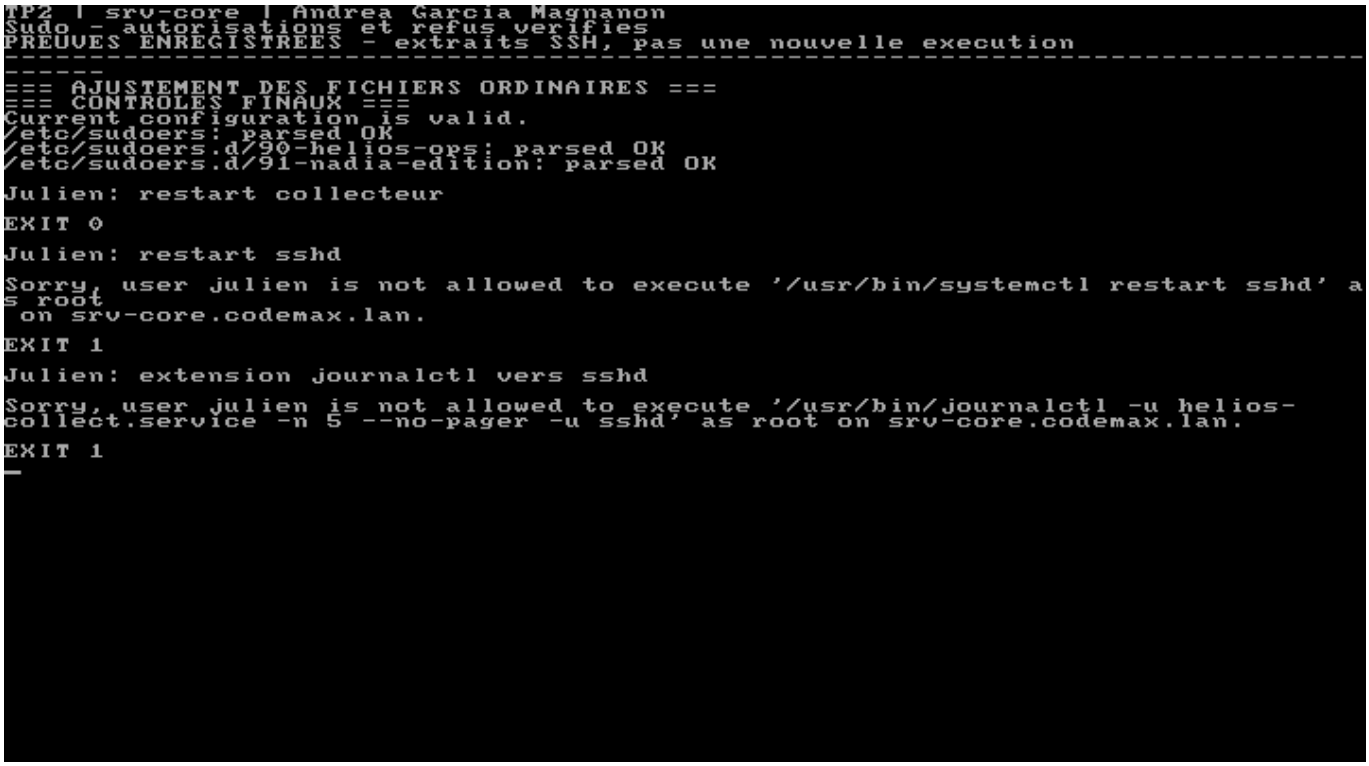


Figure 7 — Validation syntaxique et refus des commandes non déléguées.

J'ai d'abord testé la règle fournie, puis remplacé les jokers * de `journalctl` par des arguments exacts, **-n 5 --no-pager**. Cela évite d'ajouter d'autres unités ou options. Le statut du collecteur utilise aussi `systemctl --no-pager status`. L'original est conservé dans `90-helios-ops-enonce` pour expliquer la différence. La liste d'interdictions `DANGEREUX` ne remplace pas une liste d'autorisations étroite : une commande autorisée capable de lancer un shell resterait un problème.

7.1. Relecture et journalisation



Figure 8 — Sessions de Julien et relecture sudo.

`sudoreplay -l user julien` contient notamment **TSID=000007** pour le redémarrage et **TSID=000008** pour le journal. Cette dernière session a été rejouée avec succès. Les événements autorisés et refusés figurent aussi dans le journal sudo. Les transcriptions complètes sont dans `finalisation.txt` et `controle-final.txt`.

8. Évasion par vim et correction par sudoedit

Pour la démonstration demandée, j'ai posé temporairement `99-mauvais-exemple`, qui autorise Nadia à lancer vim en root sur les fichiers du projet sans mot de passe. La syntaxe valide de cette règle ne la rend pas sûre.

Dans un terminal SSH de Nadia, j'ai lancé `sudo vim` sur `tournee-nadia.csv`, puis exécuté `:!/usr/bin/id` : la sortie donne **uid=0(root)**. Avec `:!/usr/bin/bash`, le shell obtenu confirme encore cette identité. Le chemin du fichier autorisé ne limite pas les commandes que vim peut lancer avec ses propres privilèges.

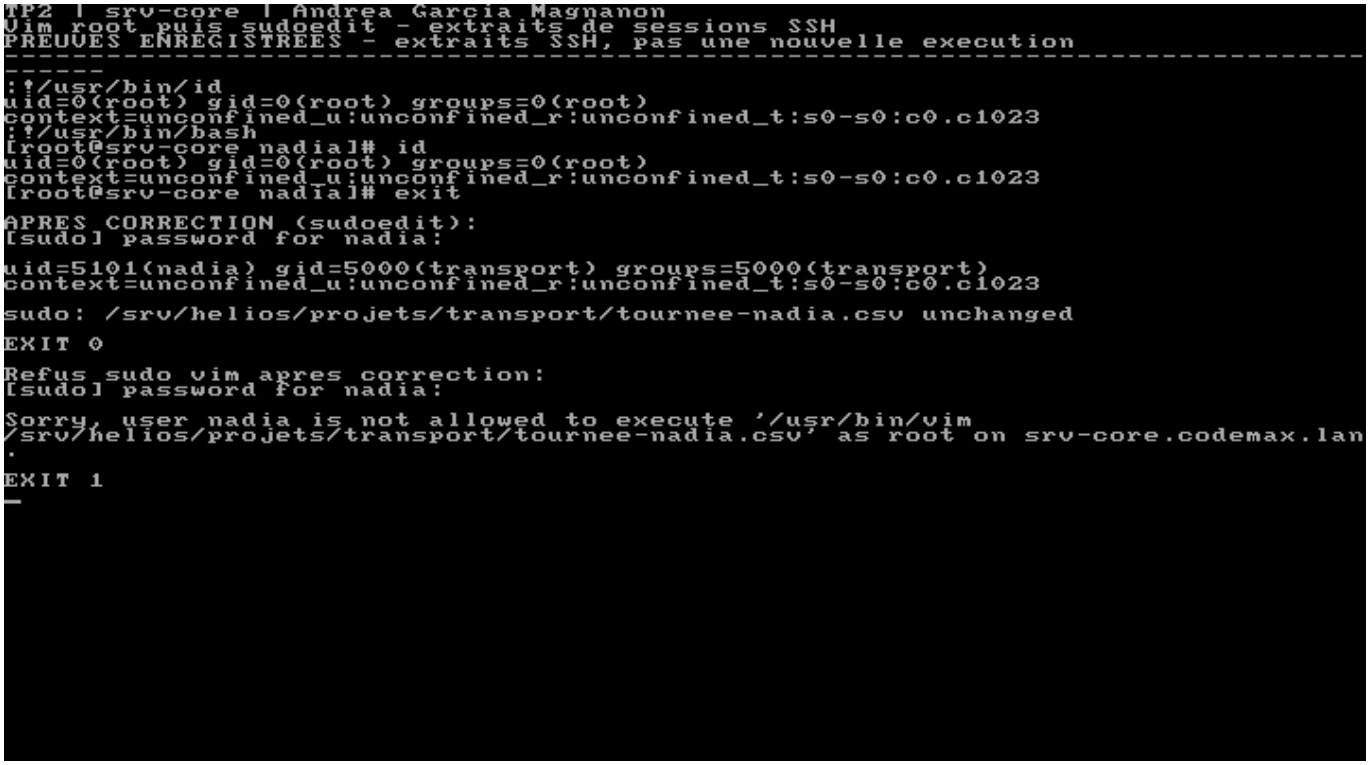


Figure 9 — Identité root avec vim, puis identité Nadia avec sudoedit.

La règle dangereuse a été retirée après le test. J'ai ajouté `91-nadia-edition`, qui autorise **sudoedit sur le seul fichier tournee-nadia.csv**. Son périmètre est plus étroit que le joker proposé dans l'énoncé. Comme Nadia peut écrire dans le répertoire, `!sudoedit_checkdir` est nécessaire pour cet exercice ; l'exception est limitée à Nadia.

Avec sudoedit, l'éditeur travaille sur une copie temporaire sous l'identité de Nadia. Une commande `id` lancée depuis cet éditeur donne **uid=5101(nadia)**. Le test se termine sans changer le fichier. Après correction, `sudo vim` est refusé avec **rc=1**.

L'utilisation de sudoedit évite donc de lancer l'éditeur en root. L'exception sur le répertoire inscriptible reste un compromis du TP, à réévaluer pour un vrai partage administré. Nadia reste propriétaire de son fichier ; cette règle sert ici à démontrer la différence de contexte d'exécution.

Preuves : `evasion-vim.txt` conserve la session brute avec ses séquences de terminal ; `sudoedit-sans-elevation.txt` et `validation-sudo-5.txt` montrent les contrôles après correction. La règle temporaire et le faux script setuid sont absents à la fin du TP.

9. Auto-audit et état du rendu

Je n'avais pas de poste de binôme à auditer. J'ai donc appliqué localement les commandes du bonus en lecture seule, puis rédigé ces cinq constats. **L'audit croisé avec un binôme n'a pas été réalisé.** Les corrections des exercices sont distinguées de cette phase d'observation.

Constat vérifié	Remédiation ou contrôle
Le droit `other::r--` d'anciens fichiers rendait la lecture possible sans ACL nominative. Il a été retiré.	`find /srv/helios/projets/transport -type f -exec setfacl -n -m o::--- {} +` ; conserver les ACL par défaut avec `other::---`.
L'entrée par défaut `audit-ext:r--` empêchait la traversée des nouveaux dossiers. Elle est corrigée.	`setfacl -d -m u:audit-ext:rx /srv/helios/projets/transport` ; corriger aussi l'ACL d'accès des dossiers déjà créés.
La règle temporaire sudo vim permettait d'obtenir root. Elle a été supprimée et remplacée par sudoedit.	Retirer `/etc/sudoers.d/99-mauvais-exemple`, poser `91-nadia-edition`, puis lancer `visudo -c`.
Les jokers de journalctl ne limitaient pas exactement les arguments. La règle finale est plus stricte.	Remplacer la liste d'arguments par `-u helios-collect.service -n 5 --no-pager` et l'équivalent archive ; tester le refus d'une unité ajoutée.
Le dépôt est le seul élément world-writable trouvé sous `/srv` et `/home` ; son sticky bit est bien actif.	Maintenir `chmod 1777 /srv/helios/depot` ; éviter un passage durable en 0777.

Les commandes d'audit n'ont trouvé aucun compte avec un champ de mot de passe vide. Tarek et l'auditeur n'ont pas de délégation sudo. Le compte de l'auditeur a bien une date d'expiration. Les mots de passe de laboratoire prescrits par le sujet ne constituent pas une politique de production : un déploiement réel demanderait des secrets individuels.

Le contrôle final confirme les UID et groupes, les modes des répertoires, le binaire setgid, les umask, les ACL héritées, les refus de l'auditeur et la validité de sudoers. Le collecteur est **actif**, et le collecteur ainsi que le timer d'archivage du TP1 sont toujours activés. Les résultats des huit tests de délégation et d'isolation de sudoedit figurent dans `validation-sudo.json`.

Le rendu contient `configs/` avec les configurations effectivement installées, le diff de login.defs, le code C, la sauvegarde ACL et l'archive avec ACL ; `captures/` avec les transcriptions et neuf captures de console ; ce rapport en Markdown et PDF. Aucune clé SSH, aucun fichier shadow ni mot de passe d'administration n'est joint.

L'expiration, le verrouillage et le reset ont été vérifiés par les commandes du sujet. Le déverrouillage automatique au bout de 600 secondes et l'expiration effective du compte le 24 novembre n'ont pas fait l'objet d'une attente en temps réel. Leurs valeurs de configuration sont contrôlées et conservées dans les preuves.